

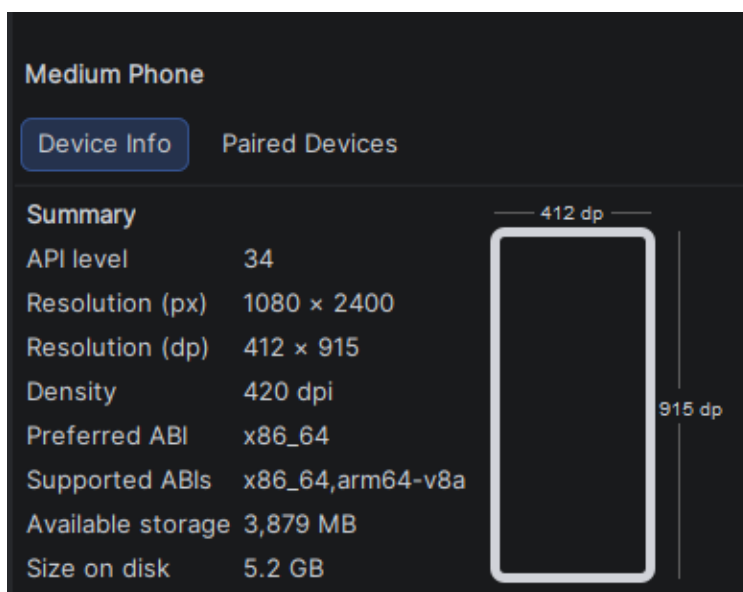
1-4

Bài 1

- Vì dùng genymotion phải tải thêm virtualbox và nếu muốn code app để check các thứ khá bất tiện nên sẽ dùng hoàn toàn android studio và AVD để root

Bài 2

- Thông tin emulator



- Vì app test đang khai báo `targetSdkVersion = 22` nhưng thiết bị emulator này sử dụng android 14 yêu cầu min version phải 23

```
Performing Streamed Install
adb.exe: failed to install InsecureBankv2.apk: Failure [INSTALL_FAILED_DEPRECATED_SDK_VERSION: App package must target at least
SDK version 23, but found 22]
```

- Tiến hành bypass `adb install --bypass-low-target-sdk-block InsecureBankv2.apk`
- Xem log thông qua `adb logcat`
- Push file vào emulator `adb push <path file host> <path file emulator>`

```
E:\Vdt2026>adb push E:\Vdt2026\testbai2.txt /data/local/tmp
E:\Vdt2026\testbai2.txt: 1 file pushed, 0 skipped. 0.0 MB/s (7 bytes in 0.008s)
```

```
emu64xa:/data/local/tmp # cat testbai2.txt
Okoonzzemu64xa:/data/local/tmp # |
```

- Kéo file từ emulator về `adb pull <path file emulator> <path file host>`

```
emu64xa:/data/local/tmp # echo "okoonzz pull" > testpull.txt
emu64xa:/data/local/tmp # ls
testpull.txt
emu64xa:/data/local/tmp # adb pull testpull.txt E:\Vdt2026
/system/bin/sh: adb: inaccessible or not found
127|emu64xa:/data/local/tmp # exit
127|emu64xa:/ $ exit

E:\Vdt2026>adb pull /data/local/tmp/testpull.txt E:\Vdt2026
\data/local/tmp/testpull.txt: 1 file pulled, 0 skipped. 0.0 MB/s (13 bytes in 0.551s)
```

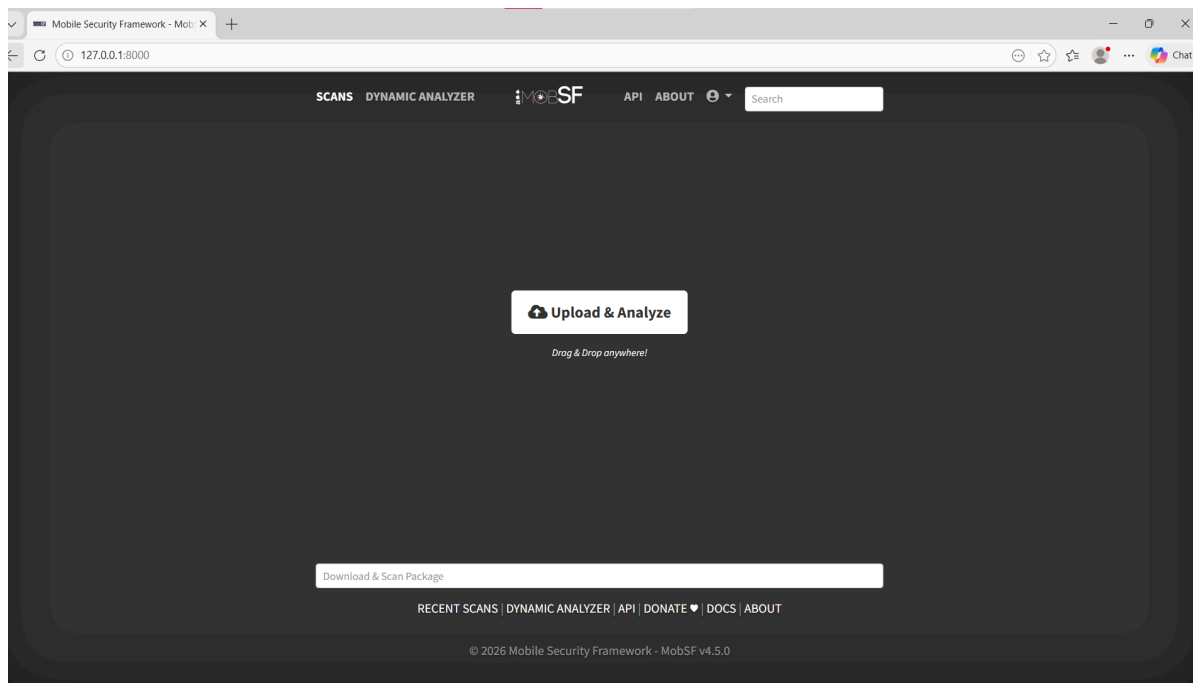
File Edit View

okoonzz pull

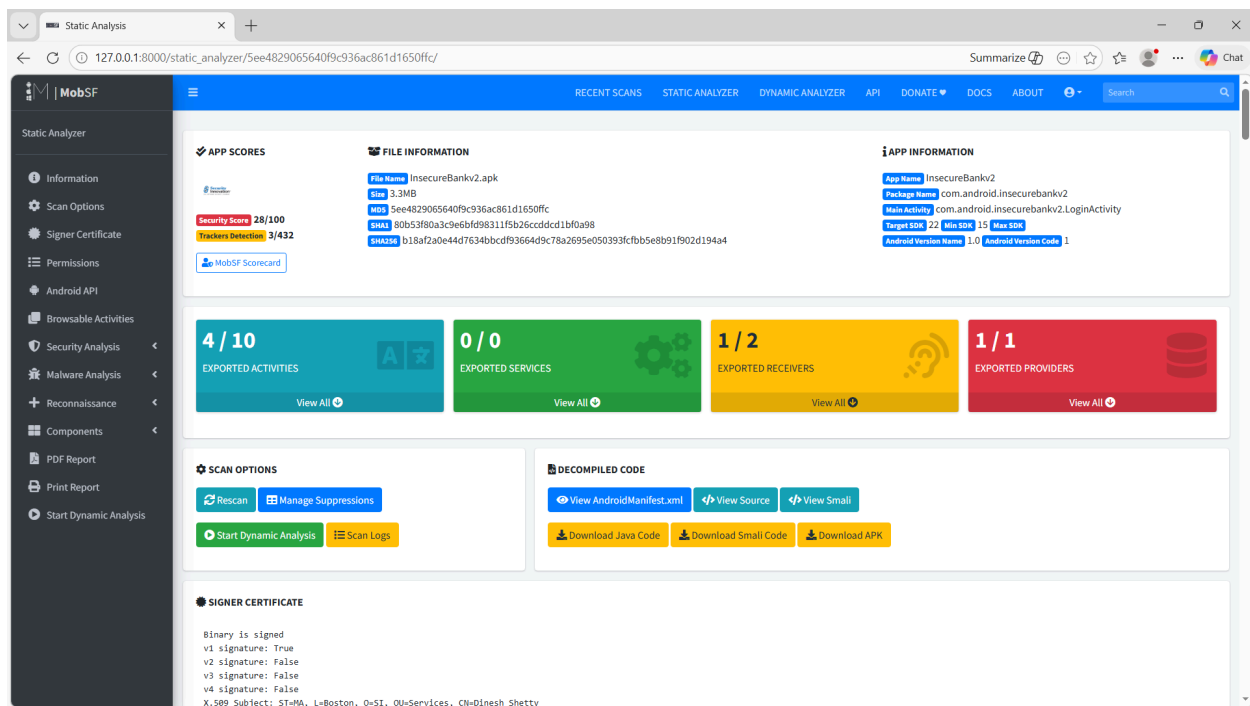
Bài 3

MobSF

- Là công cụ kiểm thử tự động android/ios/win, phân tích mal, hỗ trợ cả về tĩnh và động. Kết quả từ MobSF dùng để đánh giá sơ bộ về độ bảo mật của một chương trình
- Cài đặt MobSF
 - clone <https://github.com/MobSF/Mobile-Security-Framework-MobSF>
 - Cài đặt python, openssl
 - Chạy `setup.bat`
 - Chạy `run.bat 127.0.0.1:8000`



- Upload apk lên để phân tích



- Kiểm tra phân quyền
 - `android.permission.ACCESS_COARSE_LOCATION` : MobSF đánh dấu là **dangerous**. Cho phép app lấy **vị trí gần đúng** dựa trên mạng di động/Wi-Fi

- `android.permission.GET_ACCOUNTS` : Quyền này cho phép app lấy danh sách tài khoản trên thiết bị, ví dụ Google account hoặc các account được lưu trong Android Account Manager
- `android.permission.INTERNET` : Quyền này cho phép app tạo kết nối mạng. Một app ngân hàng chắc chắn cần quyền này để kết nối server. Tuy nhiên khi kết hợp với các quyền khác như `READ_CONTACTS`, `GET_ACCOUNTS`, `ACCESS_COARSE_LOCATION`, ... thì risk tăng lên vì get in4 xong gửi ra ngoài
- `android.permission.READ_CONTACTS` : Quyền này cho phép đọc danh bạ người dùng, nếu app ko có chức năng này thì đây khá risk

Static Analysis

127.0.0.1:8000/static_analyzer/See48290656409c936ac861d1650ffc/#permissions

Static Analyzer

Information
Scan Options
Signer Certificate
Permissions
Android API
Browsable Activities
Security Analysis
Malware Analysis
Reconnaissance
Components
PDF Report
Print Report
Start Dynamic Analysis

RECENT SCANS
STATIC ANALYZER
DYNAMIC ANALYZER
API
DONATE
DOCS
ABOUT

APPLICATION PERMISSIONS

Search:

PERMISSION	STATUS	INFO	DESCRIPTION	CODE MAPPINGS
android.permission.ACCESS_COARSE_LOCATION	dangerous	coarse (network-based) location	Access coarse location sources, such as the mobile network database, to determine an approximate phone location, where available. Malicious applications can use this to determine approximately where you are.	
android.permission.ACCESS_NETWORK_STATE	normal	view network status	Allows an application to view the status of all networks.	
android.permission.GET_ACCOUNTS	dangerous	list accounts	Allows access to the list of accounts in the Accounts Service.	
android.permission.INTERNET	normal	full Internet access	Allows an application to create network sockets.	
android.permission.READ_CONTACTS	dangerous	read contact data	Allows an application to read all of the contact (address) data stored on your phone. Malicious applications can use this to send your data to other people.	
android.permission.READ_PROFILE	dangerous	read the user's personal profile data	Allows an application to read the user's personal profile data.	
android.permission.SEND_SMS	dangerous	send SMS messages	Allows application to send SMS messages. Malicious applications may cost you money by sending messages without your confirmation.	
android.permission.USE_CREDENTIALS	dangerous	use the authentication credentials of an account	Allows an application to request authentication tokens.	
android.permission.WRITE_EXTERNAL_STORAGE	dangerous	read/modify/delete external storage contents	Allows an application to write to external storage.	

Showing 1 to 9 of 9 entries

Previous 1 Next

• Kiểm tra manifest

- App khá cũ nên mobsf alert
- Mở debug `android:debuggable=true` ⇒ risk
- Cho phép backup dữ liệu `android:allowBackup=true` ⇒ vì cho phép backup qua adb ⇒ risk
- `PostLogin` không được bảo vệ `android:exported=true` tức là có thể được app khác trên cùng thiết bị gọi trực tiếp ⇒ bypass luồng, authen, ...

- StrandHogg 2.0 - Android quản lý giao diện app bằng các **Activity** và xếp chúng trong một **task/back stack**. StrandHogg 2.0 lợi dụng cơ chế này để app độc hại có thể chèn một màn hình giả vào luồng giao diện của app thật - trên PostLogin, DoTransfer, ViewState,...

The screenshot shows the MobSF Static Analyzer web interface. The left sidebar contains navigation options like Information, Scan Options, Signer Certificate, Permissions, Android API, Browsable Activities, Security Analysis, Malware Analysis, Reconnaissance, Components, PDF Report, Print Report, and Start Dynamic Analysis. The main area displays a table of detected issues.

NO	ISSUE	SEVERITY	DESCRIPTION	OPTIONS
1	App can be installed on a vulnerable unpatched Android version 4.0.3-4.0.4, [minSdk=15]	High	This application can be installed on an older version of android that has multiple unfixed vulnerabilities. These devices won't receive reasonable security updates from Google. Support an Android version >= 10, API 29 to receive reasonable security updates.	[Options]
2	Debug Enabled For App [android:debuggable=true]	High	Debugging was enabled on the app which makes it easier for reverse engineers to hook a debugger to it. This allows dumping a stack trace and accessing debugging helper classes.	[Options]
3	Application Data can be Backed up [android:allowBackup=true]	Warning	This flag allows anyone to backup your application data via adb. It allows users who have enabled USB debugging to copy application data off of the device.	[Options]
4	Activity (com.android.insecurebankv2.PostLogin) is vulnerable to StrandHogg 2.0	High	Activity is found to be vulnerable to StrandHogg 2.0 task hijacking vulnerability. When vulnerable, it is possible for other applications to place a malicious activity on top of the activity stack of the vulnerable application. This makes the application an easy target for phishing attacks. The vulnerability can be remediated by setting the launch mode attribute to "singleInstance" and by setting an empty taskAffinity (taskAffinity=""). You can also update the target SDK version (22) of the app to 29 or higher to fix this issue at platform level.	[Options]
5	Activity (com.android.insecurebankv2.PostLogin) is not Protected. [android:exported=true]	Warning	An Activity is found to be shared with other apps on the device therefore leaving it accessible to any other application on the device.	[Options]
6	Activity (com.android.insecurebankv2.DoTransfer) is vulnerable to StrandHogg 2.0	High	Activity is found to be vulnerable to StrandHogg 2.0 task hijacking vulnerability. When vulnerable, it is possible for other applications to place a malicious activity on top of the activity stack of the vulnerable application. This makes the application an easy target for phishing attacks. The vulnerability can be remediated by setting the launch mode attribute to "singleInstance" and by setting an empty taskAffinity (taskAffinity=""). You can also update the target SDK version (22) of the app to 29 or higher to fix this issue at platform level.	[Options]
7	Activity (com.android.insecurebankv2.DoTransfer) is not Protected. [android:exported=true]	Warning	An Activity is found to be shared with other apps on the device therefore leaving it accessible to any other application on the device.	[Options]
8	Activity (com.android.insecurebankv2.ViewStatement) is vulnerable to StrandHogg 2.0	High	Activity is found to be vulnerable to StrandHogg 2.0 task hijacking vulnerability. When vulnerable, it is possible for other applications to place a malicious activity on top of the activity stack of the vulnerable application. This makes the application an easy target for phishing attacks. The vulnerability can be remediated by setting the launch mode attribute to "singleInstance" and by setting an empty taskAffinity (taskAffinity=""). You can also update the target SDK	[Options]

- Show các activity trong app

ACTIVITIES

▼ Showing all **10** activities

[com.android.insecurebankv2.LoginActivity](#)
[com.android.insecurebankv2.FilePrefActivity](#)
[com.android.insecurebankv2.DoLogin](#)
[com.android.insecurebankv2.PostLogin](#)
[com.android.insecurebankv2.WrongLogin](#)
[com.android.insecurebankv2.DoTransfer](#)
[com.android.insecurebankv2.ViewStatement](#)
[com.android.insecurebankv2.ChangePassword](#)
[com.google.android.gms.ads.AdActivity](#)
[com.google.android.gms.ads.purchase.InAppPurchaseActivity](#)

- Show các string trong app

A STRINGS

From APK Resource

From Code

▼ Show all **6474** strings

Error creating instance of class

Activity context is not available

single

start new dispatcher

closetype

Could not forward onStop to ad overlay:

Initiating WebView self destruct sequence in 3...

tuple_id

Statement does not Exist!!

notificationSettings is required.

android.speech.action.RECOGNIZE_SPEECH

sync_token

ServiceUnavailable

promotion should be non-null

turn_based_support

Error deleting entries

analytics_pass_through

accessibility

IconImageUrl

s://a.b.c?

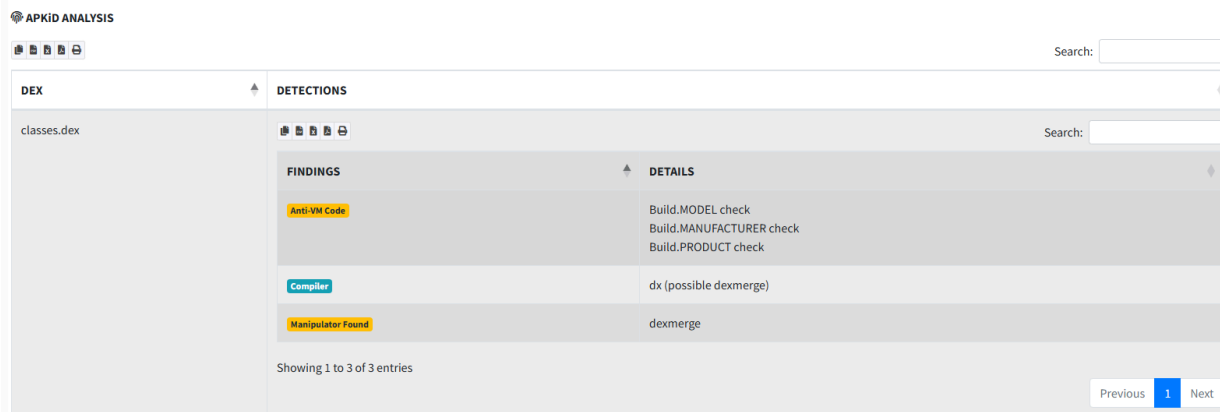
Couldn't fetch mRecreateDisplayList field; dimming will be slow.

Width must have an exact value or MATCH_PARENT

STATUS_REQUEST_UPDATE_PARTIAL_SUCCESS

ownedByMe()

- APKID phát hiện app có check sử dụng máy thật hay emulator



Kiểm tra thông tin đăng nhập trong cơ sở dữ liệu

- Đăng nhập với thông tin `dinesh/Dinesh@123$` sau đó pull database về máy. Vì pull về cần quyền root nên copy database sang `tmp` rồi cấp lại quyền sau đó pull về
- Check không thấy db lưu thông tin gì nhạy cảm $\Rightarrow$ safe

```
SQLite version 3.44.2 2023-11-24 11:41:44 (UTF-16 console I/O)
Enter ".help" for usage hints.
Connected to a transient in-memory database.
Use ".open FILENAME" to reopen on a persistent database.
sqlite> .open mydb
sqlite> .tables
android_metadata  names
sqlite> select *from names;
1|dinesh
```

- Tìm kiếm các thông tin nhạy cảm lưu dưới plaintext `grep -r 'device' $(find)` như `deviceid, phone, uuid,...` không thấy $\Rightarrow$ safe

Backup file

- Vì MobSF alert app cho phép backup, thử backup và xem nội dung backup `adb backup -apk -shared com.android.insecurebankv2`
- Dùng `java -jar abe-540a57d.jar unpack backup.ab backup.tar` để extract file backup
- Thấy được thông tin server cũng như mã hóa username khá yếu bằng base64

This XML file does not appear to have any style information associated with it. The document tree is shown below.

```
<map>
  <string name="superSecurePassword">DTrW2VXjSoFdG0e61fHxJg== </string>
  <string name="EncryptedUsername">ZGluZXNo </string>
</map>
```

Thông tin đăng nhập lộ ở log

- Dùng `adb logcat` và đăng nhập thì thấy lộ thông tin

```
05-17 22:44:04.699 777 826 V WindowManagerShell: Track 0 became idle
05-17 22:44:04.699 777 826 V WindowManagerShell: All active transition animations finished
05-17 22:44:04.729 423 534 D audioserver: FGS Logger Transaction failed
05-17 22:44:04.729 423 534 D audioserver: -129
05-17 22:44:05.145 22302 22558 I TrafficStats: untagSocket(108)
05-17 22:44:05.146 22302 22558 D Successful Login:: , account=dinesh:Dinesh@123$|
05-17 22:44:05.156 562 2317 W ActivityTaskManager: startActivity called from non-Activity context; forcing Intent.FLAG_ACTIVITY
05-17 22:44:05.163 562 2317 E Transition: Trying to add a ready-group twice: Display{#0 state=ON size=1080x2400 ROTATION_0}
05-17 22:44:05.164 562 2317 I ActivityTaskManager: START u0 {cmp=com.android.insecurebankv2/.PostLogin (has extras)} with LAUNCH
05-17 22:44:05.165 777 826 V WindowManagerShell: Transition requested: android.os.BinderProxy@a9f6463 TransitionRequestInfo {
```

Mã hóa yếu

- Key và IV được set cứng mặc dù thuật toán mã hóa mạnh

```
/* loaded from: classes.dex */
50 public class CryptoClass {
    String base64Text;
    byte[] cipherData;
    String cipherText;
    String plainText;
    String key = "This is the super secret key 123";
    byte[] ivBytes = {0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0};

51 public static byte[] aes256encrypt(byte[] ivBytes, byte[] keyBytes, byte[] textBytes) throws UnsupportedOperationException, NoSuchAlgorithmException, NoSuchPaddingException, InvalidKeyException {
52     AlgorithmParameterSpec ivSpec = new IvParameterSpec(ivBytes);
53     SecretKeySpec newKey = new SecretKeySpec(keyBytes, "AES");
54     Cipher cipher = Cipher.getInstance("AES/CBC/PKCS5Padding");
55     cipher.init(1, newKey, ivSpec);
56     return cipher.doFinal(textBytes);
57 }

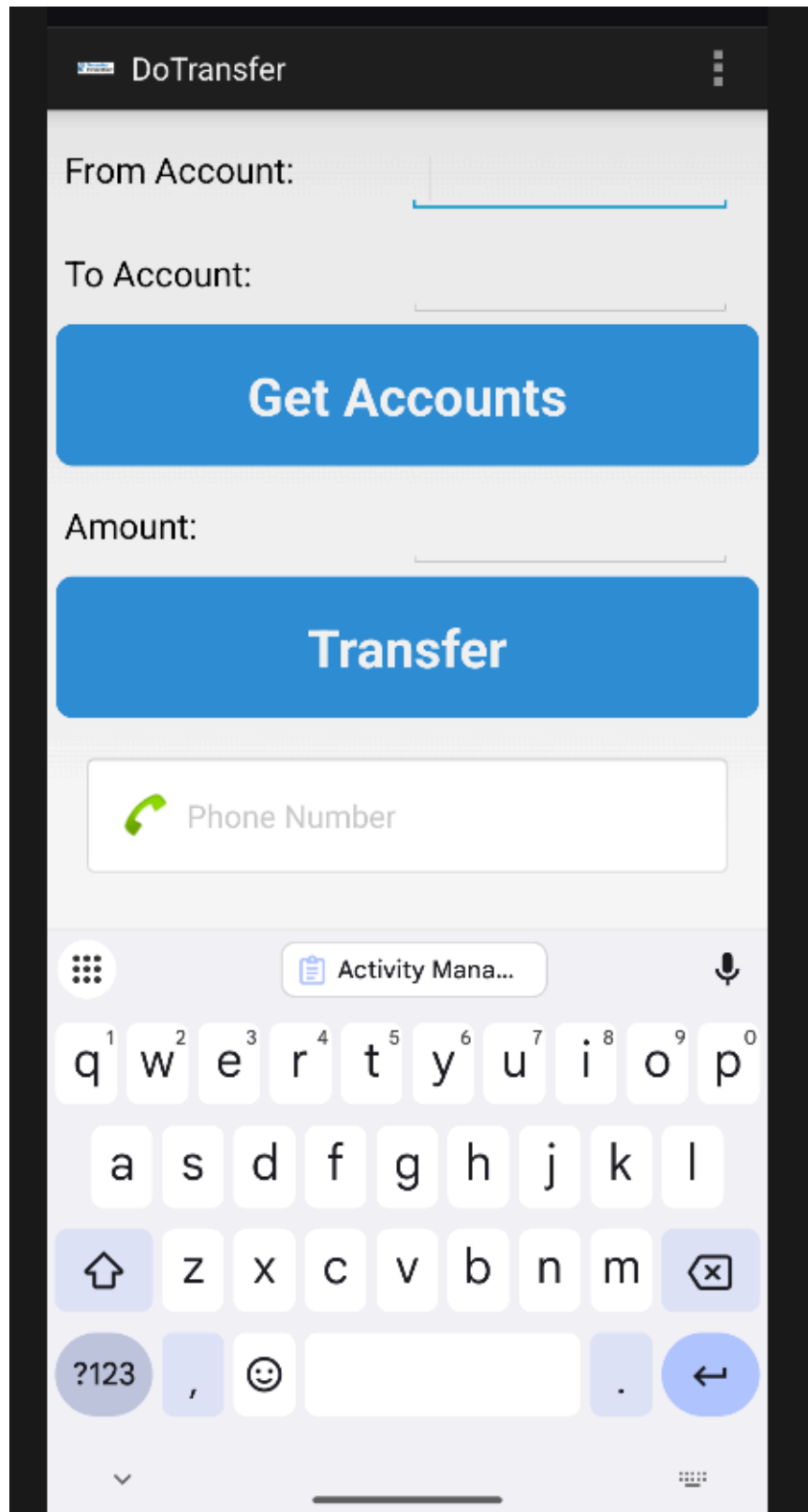
74 public static byte[] aes256decrypt(byte[] ivBytes, byte[] keyBytes, byte[] textBytes) throws UnsupportedOperationException, NoSuchAlgorithmException, NoSuchPaddingException, InvalidKeyException {
75     AlgorithmParameterSpec ivSpec = new IvParameterSpec(ivBytes);
76     SecretKeySpec newKey = new SecretKeySpec(keyBytes, "AES");
77     Cipher cipher = Cipher.getInstance("AES/CBC/PKCS5Padding");
78     cipher.init(2, newKey, ivSpec);
79     return cipher.doFinal(textBytes);
80 }

89 public String aesDecryptedString(String theString) throws UnsupportedOperationException, InvalidKeyException, NoSuchAlgorithmException, NoSuchPaddingException, InvalidAlgorithmParameterException {
90     byte[] keyBytes = this.key.getBytes("UTF-8");
91     this.cipherData = aes256decrypt(this.ivBytes, keyBytes, Base64.decode(theString.getBytes("UTF-8"), 0));
92     this.plainText = new String(this.cipherData, "UTF-8");
93     return this.plainText;
94 }

95 public String aesEncryptedString(String theString) throws UnsupportedOperationException, InvalidKeyException, NoSuchAlgorithmException, NoSuchPaddingException, InvalidAlgorithmParameterException {
96     byte[] keyBytes = this.key.getBytes("UTF-8");
97     this.plainText = theString;
98     this.cipherData = aes256encrypt(this.ivBytes, keyBytes, this.plainText.getBytes("UTF-8"));
99     this.cipherText = Base64.encodeToString(this.cipherData, 0);
100    return this.cipherText;
101 }
```

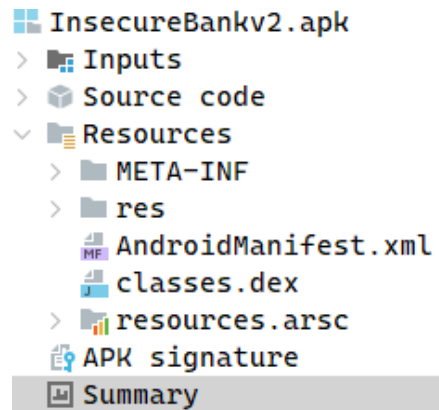
Hijacking

- Vì như MobSF có alert thì activity có export là true nên dùng `am start -n com.android.insecurebankv2/.DoTransfer` - `am` Activity Manager giúp **mở màn hình app, gửi intent (start), gọi broadcast, start service, force-stop app** từ terminal. App tự chuyển đến không cần đăng nhập



Bài 4

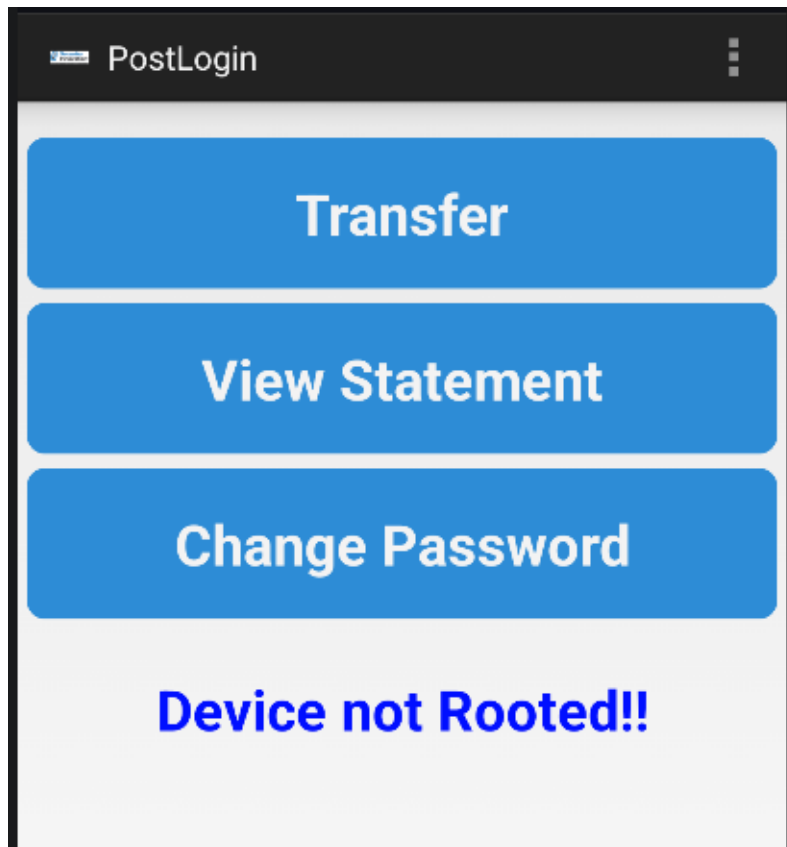
Cấu trúc file APK



- `META-INF` có trong các file apk đã sign và chứa các cert
- `lib` chứa native lib để app sử dụng (`.so`)
- `res` chứa tất cả XML
- `AndroidManifest.xml` tên, phiên bản, các quyền (permission), các thành phần (activity, service, provider,...) trong app
- `class.dex` mã nguồn của ứng dụng đã được biên dịch thành bytecode
- `resources.arsc` tài nguyên đã được biên dịch thành bảng tra cứu, liên kết mã nguồn với các tài nguyên trong thư mục `res`

Decompile + rev + patch

- Vì phần này trong github khá dài nên sẽ làm lại và chung 1 phần. Về cơ bản vẫn sẽ là decompile > rev > patch
- Để decompile file apk sử dụng `apktool d <name>.apk` và bytecode sẽ chuyển thành smali



- Rõ ràng device đã được rooted nhưng tại sao app lại bảo device chưa root? Mở jadx tiến hành rev.
- Ở activity PostLogin có đoạn check `Superuser.apk` và một hàm check process

```

void showRootStatus() {
    boolean isrooted = doesSuperuserApkExist("/system/app/Superuser.apk") || doesSUexist();
    if (isrooted) {
        this.root_status.setText("Rooted Device!!");
    } else {
        this.root_status.setText("Device not Rooted!!");
    }
}

private boolean doesSUexist() {
    Process process = null;
    try {
        process = Runtime.getRuntime().exec(new String[]{"/system/xbin/which", "su"});
        BufferedReader in = new BufferedReader(new InputStreamReader(process.getInputStream()));
        if (in.readLine() == null) {
            if (process != null) {
                process.destroy();
            }
            return false;
        }
        if (process == null) {
            return true;
        }
        process.destroy();
        return true;
    } catch (Throwable th) {
        if (process != null) {
            process.destroy();
        }
        throw th;
    }
}

```

- Hai hàm check này đều trả về false, đối với hàm đầu tiên vì app đang check sai path và check khá cũ đối với root mới, path đúng phải là `/system/bin/which`
- Tiến hành decompile (`apktool_3.0.2.jar d InsecureBankv2.apk`) và tìm đoạn smali tương ứng

```

50
51     const/4 v7, 0x0
52
53     const-string v8, "/system/xbin/which"
54
55     aput-object v8, v6, v7

```

- Sửa và patch
 - `apktool_3.0.2.jar b InsecureBankv2 -o InsecureBankv3.apk`
 - `keytool -genkeypair -v -keystore InsecureBankv3.keystore -alias InsecureBankv3 -keyalg RSA -keysize 2048 -validity 10000`

- `apksigner sign --ks InsecureBankv3.keystore InsecureBankv3.apk`
- Hoàn thành

